

NIST Cybersecurity Framework

What is NIST?

NIST stands for **National Institute of Standards and Technology**.

It is a **U.S. government agency** under the **U.S. Department of Commerce**.

NIST develops cybersecurity standards, guidelines, and best practices to help organizations manage cybersecurity risks.

Unlike ISC2, NIST **does not issue professional certifications** such as CISSP.

What is the NIST Cybersecurity Framework (CSF)?

The **NIST Cybersecurity Framework (CSF)** is a **risk-based cybersecurity framework** that helps organizations identify, protect, detect, respond to, and recover from cybersecurity threats.

Simple Definition

The NIST CSF is a roadmap that helps organizations build, manage, and continuously improve their cybersecurity program.

It is **not a certification**.

It is a **framework** used by organizations to strengthen their cybersecurity posture.

Why was NIST CSF Created?

Before NIST CSF, organizations followed different security practices and lacked a common approach to managing cyber risks.

NIST created the framework to provide a structured, flexible, and risk-based method for improving cybersecurity.

The framework helps organizations answer questions such as:

- What assets do we own?

- What should we protect?
 - How do we detect cyber attacks?
 - How do we respond to incidents?
 - How do we recover after an attack?
-

Brief History

1988

NIST began publishing cybersecurity standards and guidance for U.S. federal agencies.



2013

Executive Order 13636 directed NIST to develop a cybersecurity framework for critical infrastructure.



2014

NIST released **Cybersecurity Framework Version 1.0**.



2018

Version **1.1** added improvements, including supply chain risk guidance.



2024

NIST released **CSF 2.0**, expanding the framework for organizations of all sizes.

NIST CSF 2.0 Core Functions

The framework consists of **6 Core Functions**.

1. Govern

Purpose

Establish cybersecurity governance and risk management.

Focus Areas

- Security Policies
- Governance
- Risk Management
- Roles & Responsibilities
- Compliance
- Leadership
- Security Strategy

Simple Question

"How will we manage cybersecurity?"

2. Identify

Purpose

Understand what the organization owns and what needs protection.

Focus Areas

- Asset Inventory
- Business Environment
- Risk Assessment
- Critical Systems
- Data Classification

Simple Question

"What are we protecting?"

3. Protect

Purpose

Implement safeguards to reduce cyber risks.

Focus Areas

- Access Control
- Multi-Factor Authentication (MFA)
- Encryption
- Security Awareness Training
- Patch Management
- Data Protection

Simple Question

"How do we protect our assets?"

4. Detect

Purpose

Detect cybersecurity events as quickly as possible.

Focus Areas

- SIEM
- IDS
- EDR
- Log Monitoring
- Threat Detection

Simple Question

"Has an attack occurred?"

5. Respond

Purpose

Take action after detecting a cybersecurity incident.

Focus Areas

- Incident Response
- Containment
- Investigation
- Communication
- Eradication

Simple Question

"What should we do after detecting an attack?"

6. Recover

Purpose

Restore systems and business operations after an incident.

Focus Areas

- Backups
- Disaster Recovery
- Business Continuity
- Lessons Learned
- Service Restoration

Simple Question

"How do we return to normal operations?"



there's an important difference between **CISSP** and **NIST CSF**.

CISSP

Think of **CISSP** as the complete knowledge of cybersecurity.

It teaches a security professional:

- Why security is needed
- What should be protected
- How to design secure systems
- How to secure networks
- How to manage identities and access
- How to test security
- How to operate security every day
- How to build secure software

It answers:

"What should a cybersecurity professional know?"

It is **knowledge-oriented**.

NIST Cybersecurity Framework (CSF)

Think of **NIST CSF as the organization's cybersecurity roadmap**.

It tells an organization:

1. **Govern** → Create policies, leadership, and risk management.
2. **Identify** → Identify assets, systems, and risks.
3. **Protect** → Implement security controls (MFA, encryption, firewalls, etc.).
4. **Detect** → Monitor systems and detect attacks.
5. **Respond** → Contain and investigate incidents.
6. **Recover** → Restore systems and improve after the incident.

It answers:

"How should an organization manage cybersecurity?"

It is **process-oriented**.

Real-World Example

Imagine you're working at a bank.

CISSP gives you the knowledge to understand:

- Risk Management
- Asset Security
- IAM
- Network Security
- Security Operations

- Secure Software Development

Then the bank uses **NIST CSF** as its operating framework:

- **Govern** → Create security policies and assign responsibilities.
 - **Identify** → List all servers, laptops, databases, and sensitive data.
 - **Protect** → Enable MFA, encryption, EDR, and firewalls.
 - **Detect** → Use SIEM and IDS to monitor for attacks.
 - **Respond** → Follow the incident response plan.
 - **Recover** → Restore systems from backups and improve controls.
-

In one sentence:

- **CISSP = Teaches you cybersecurity.**
- **NIST CSF = Teaches an organization how to manage cybersecurity.**

So yes, your understanding is essentially correct. Just remember that **CISSP is a body of professional knowledge**, while **NIST CSF is a framework that organizations use to apply that knowledge in practice.**
